Microsoft Entra security operations guide

Microsoft has a successful and proven approach to Zero Trust security using Defense in Depth principles that use identity as a control plane. Organizations continue to embrace a hybrid workload world for scale, cost savings, and security. Microsoft Entra ID plays a pivotal role in your strategy for identity management. Recently, news surrounding identity and security compromise has increasingly prompted enterprise IT to consider their identity security posture as a measurement of defensive security success.

Increasingly, organizations must embrace a mixture of on-premises and cloud applications, which users access with both on–premises and cloud-only accounts. Managing users, applications, and devices both on-premises and in the cloud poses challenging scenarios.

Hybrid identity

Microsoft Entra ID creates a common user identity for authentication and authorization to all resources, regardless of location. We call this *hybrid identity*.

To achieve hybrid identity with Microsoft Entra ID, one of three authentication methods can be used, depending on your scenarios. The three methods are:

- Password hash synchronization (PHS)
- Pass-through authentication (PTA)
- Federation (AD FS)

As you audit your current security operations or establish security operations for your Azure environment, we recommend you:

- Read specific portions of the Microsoft security guidance to establish a baseline of knowledge about securing your cloud-based or hybrid Azure environment.
- Audit your account and password strategy and authentication methods to help deter the most common attack vectors.
- Create a strategy for continuous monitoring and alerting on activities that might indicate a security threat.

Audience

The Microsoft Entra SecOps Guide is intended for enterprise IT identity and security operations teams and managed service providers that need to counter threats through better identity security configuration and monitoring profiles. This guide is especially relevant for IT

administrators and identity architects advising Security Operations Center (SOC) defensive and penetration testing teams to improve and maintain their identity security posture.

Scope

This introduction provides the suggested prereading and password audit and strategy recommendations. This article also provides an overview of the tools available for hybrid Azure environments and fully cloud-based Azure environments. Finally, we provide a list of data sources you can use for monitoring and alerting and configuring your security information and event management (SIEM) strategy and environment. The rest of the guidance presents monitoring and alerting strategies in the following areas:

- User accounts. Guidance specific to non-privileged user accounts without administrative privilege, including anomalous account creation and usage, and unusual sign-ins.
- Privileged accounts. Guidance specific to privileged user accounts that have elevated permissions to perform administrative tasks. Tasks include Microsoft Entra role assignments, Azure resource role assignments, and access management for Azure resources and subscriptions.
- Privileged Identity Management (PIM). Guidance specific to using PIM to manage, control, and monitor access to resources.
- Applications. Guidance specific to accounts used to provide authentication for applications.
- Devices. Guidance specific to monitoring and alerting for devices registered or joined outside of policies, non-compliant usage, managing device administration roles, and sign-ins to virtual machines.
- Infrastructure. Guidance specific to monitoring and alerting on threats to your hybrid and purely cloud-based environments.

Important reference content

Microsoft has many products and services that enable you to customize your IT environment to fit your needs. We recommend that you review the following guidance for your operating environment:

- Windows operating systems
  - Security baseline (FINAL) for Windows 10 v1909 and Windows Server v1909
  - Security baseline for Windows 11
  - Security baseline for Windows Server 2022
- On-premises environments

    - Microsoft Defender for Identity architecture
    - Connect Microsoft Defender for Identity to Active Directory quickstart
    - Azure security baseline for Microsoft Defender for Identity
    - Monitoring Active Directory for Signs of Compromise

- Cloud-based Azure environments
    - Monitor sign-ins with the Microsoft Entra sign-in log
    - Audit activity reports in the Azure portal
    - Investigate risk with Microsoft Entra ID Protection
    - Connect Microsoft Entra ID Protection data to Microsoft Sentinel

- Active Directory Domain Services (AD DS)
    - Audit Policy Recommendations

- Active Directory Federation Services (AD FS)
    - AD FS Troubleshooting - Auditing Events and Logging

Data sources

The log files you use for investigation and monitoring are:

- Microsoft Entra audit logs
- Sign-in logs
- Microsoft 365 Audit logs
- Azure Key Vault logs

From the Azure portal, you can view the Microsoft Entra audit logs. Download logs as comma separated value (CSV) or JavaScript Object Notation (JSON) files. The Azure portal has several ways to integrate Microsoft Entra logs with other tools that allow for greater automation of monitoring and alerting:

- **Microsoft Sentinel** - Enables intelligent security analytics at the enterprise level by providing security information and event management (SIEM) capabilities.

- **Sigma rules** - Sigma is an evolving open standard for writing rules and templates that automated management tools can use to parse log files. Where Sigma templates exist for our recommended search criteria, we have added a link to the Sigma repo. The Sigma templates are not written, tested, and managed by Microsoft. Rather, the repo and templates are created and collected by the worldwide IT security community.

- **Azure Monitor** - Enables automated monitoring and alerting of various conditions. Can create or use workbooks to combine data from different sources.

- **Azure Event Hubs** integrated with a SIEM. Microsoft Entra logs can be integrated to other SIEMs such as Splunk, ArcSight, QRadar and Sumo Logic via the Azure Event Hubs integration. For more information, see Stream Microsoft Entra logs to an Azure event hub.

- **Microsoft Defender for Cloud Apps** - Enables you to discover and manage apps, govern across apps and resources, and check the compliance of your cloud apps.

- **Securing workload identities with Microsoft Entra ID Protection** - Used to detect risk on workload identities across sign-in behavior and offline indicators of compromise.

Much of what you will monitor and alert on are the effects of your Conditional Access policies. You can use the Conditional Access insights and reporting workbook to examine the effects of one or more Conditional Access policies on your sign-ins and the results of policies, including device state. This workbook enables you to view an impact summary, and identify the impact over a specific time period. You can also use the workbook to investigate the sign-ins of a specific user. For more information, see Conditional Access insights and reporting.

The remainder of this article describes what to monitor and alert on. Where there are specific pre-built solutions we link to them or provide samples following the table. Otherwise, you can build alerts using the preceding tools.

- **ID Protection** generates three key reports that you can use to help with your investigation:

- **Risky users** contains information about which users are at risk, details about detections, history of all risky sign-ins, and risk history.

- **Risky sign-ins** contains information surrounding the circumstance of a sign-in that might indicate suspicious circumstances. For more information on investigating information from this report, see How To: Investigate risk.

- **Risk detections** contains information on risk signals detected by Microsoft Entra ID Protection that informs sign-in and user risk. For more information, see the Microsoft Entra security operations guide for user accounts.

For more information, see What is Microsoft Entra ID Protection.

Data sources for domain controller monitoring

For the best results, we recommend that you monitor your domain controllers using Microsoft Defender for Identity. This approach enables the best detection and automation capabilities. Follow the guidance from these resources:

- Microsoft Defender for Identity architecture
- Connect Microsoft Defender for Identity to Active Directory quickstart

If you don't plan to use Microsoft Defender for Identity, monitor your domain controllers by one of these approaches:

- Event log messages. See Monitoring Active Directory for Signs of Compromise.
- PowerShell cmdlets. See Troubleshooting Domain Controller Deployment.

Components of hybrid authentication

As part of an Azure hybrid environment, the following items should be baselined and included in your monitoring and alerting strategy.

- **PTA Agent** - The pass-through authentication agent is used to enable pass-through authentication and is installed on-premises. See Microsoft Entra pass-through authentication agent: Version release history for information on verifying your agent version and next steps.

- **AD FS/WAP** - Active Directory Federation Services (AD FS) and Web Application Proxy (WAP) enable secure sharing of digital identity and entitlement rights across your security and enterprise boundaries. For information on security best practices, see Best practices for securing Active Directory Federation Services.

- **Microsoft Entra Connect Health Agent** - The agent used to provide a communications link for Microsoft Entra Connect Health. For information on installing the agent, see Microsoft Entra Connect Health agent installation.

- **Microsoft Entra Connect Sync Engine** - The on-premises component, also called the sync engine. For information on the feature, see Microsoft Entra Connect Sync service features.

- **Password Protection DC agent** - Azure password protection DC agent is used to help with monitoring and reporting event log messages. For information, see Enforce on-premises Microsoft Entra Password Protection for Active Directory Domain Services.

- **Password Filter DLL** - The password filter DLL of the DC Agent receives user password-validation requests from the operating system. The filter forwards them to the DC Agent service that's running locally on the DC. For information on using the DLL, see Enforce on-premises Microsoft Entra Password Protection for Active Directory Domain Services.

- **Password writeback Agent** - Password writeback is a feature enabled with Microsoft Entra Connect that allows password changes in the cloud to be written back to an existing on-premises directory in real time. For more information on this feature, see How does self-service password reset writeback work in Microsoft Entra ID.

- **Microsoft Entra private network connector** - Lightweight agents that sit on-premises and facilitate the outbound connection to the Application Proxy service. For more information,

see Microsoft Entra private network connectors.

Components of cloud-based authentication

As part of an Azure cloud-based environment, the following items should be baselined and included in your monitoring and alerting strategy.

- **Microsoft Entra application proxy** - This cloud service provides secure remote access to on-premises web applications. For more information, see Remote access to on-premises applications through Microsoft Entra application proxy.
- **Microsoft Entra Connect** - Services used for a Microsoft Entra Connect solution. For more information, see What is Microsoft Entra Connect.
- **Microsoft Entra Connect Health** - Service Health provides you with a customizable dashboard that tracks the health of your Azure services in the regions where you use them. For more information, see Microsoft Entra Connect Health.
- **Microsoft Entra multifactor authentication** - multifactor authentication requires a user to provide more than one form of proof for authentication. This approach can provide a proactive first step to securing your environment. For more information, see Microsoft Entra multifactor authentication.
- **Dynamic groups** - Dynamic configuration of security group membership for Microsoft Entra Administrators can set rules to populate groups that are created in Microsoft Entra ID based on user attributes. For more information, see Dynamic groups and Microsoft Entra B2B collaboration.
- **Conditional Access** - Conditional Access is the tool used by Microsoft Entra ID to bring signals together, to make decisions, and enforce organizational policies. Conditional Access is at the heart of the new identity driven control plane. For more information, see What is Conditional Access.
- **Microsoft Entra ID Protection** - A tool that enables organizations to automate the detection and remediation of identity-based risks, investigate risks using data in the portal, and export risk detection data to your SIEM. For more information, see What is Microsoft Entra ID Protection.
- **Group-based licensing** - Licenses can be assigned to groups rather than directly to users. Microsoft Entra ID stores information about license assignment states for users.
- **Provisioning Service** - Provisioning refers to creating user identities and roles in the cloud applications that users need access to. In addition to creating user identities, automatic provisioning includes the maintenance and removal of user identities as status or roles

change. For more information, see How Application Provisioning works in Microsoft Entra ID.

- **Graph API** - The Microsoft Graph API is a RESTful web API that enables you to access Microsoft Cloud service resources. After you register your app and get authentication tokens for a user or service, you can make requests to the Microsoft Graph API. For more information, see Overview of Microsoft Graph.

- **Domain Service** - Microsoft Entra Domain Services (AD DS) provides managed domain services such as domain join, group policy. For more information, see What is Microsoft Entra Domain Services.

- **Azure Resource Manager** - Azure Resource Manager is the deployment and management service for Azure. It provides a management layer that enables you to create, update, and delete resources in your Azure account. For more information, see What is Azure Resource Manager.

- **Managed identity** - Managed identities eliminate the need for developers to manage credentials. Managed identities provide an identity for applications to use when connecting to resources that support Microsoft Entra authentication. For more information, see What are managed identities for Azure resources.

- **Privileged Identity Management** - PIM is a service in Microsoft Entra ID that enables you to manage, control, and monitor access to important resources in your organization. For more information, see What is Microsoft Entra Privileged Identity Management.

- **Access reviews** - Microsoft Entra access reviews enable organizations to efficiently manage group memberships, access to enterprise applications, and role assignments. User's access can be reviewed regularly to make sure only the right people have continued access. For more information, see What are Microsoft Entra access reviews.

- **Entitlement management** - Microsoft Entra entitlement management is an identity governance feature. Organizations can manage identity and access lifecycle at scale, by automating access request workflows, access assignments, reviews, and expiration. For more information, see What is Microsoft Entra entitlement management.

- **Activity logs** - The Activity log is an Azure platform log that provides insight into subscription-level events. This log includes such information as when a resource is modified or when a virtual machine is started. For more information, see Azure Activity log.

- **Self-service password reset service** - Microsoft Entra self-service password reset (SSPR) gives users the ability to change or reset their password. The administrator or help desk isn't

required. For more information, see How it works: Microsoft Entra self-service password reset.

- **Device services** - Device identity management is the foundation for device-based Conditional Access. With device-based Conditional Access policies, you can ensure that access to resources in your environment is only possible with managed devices. For more information, see What is a device identity.

- **Self-service group management** - You can enable users to create and manage their own security groups or Microsoft 365 groups in Microsoft Entra ID. The owner of the group can approve or deny membership requests and can delegate control of group membership. Self-service group management features aren't available for mail-enabled security groups or distribution lists. For more information, see Set up self-service group management in Microsoft Entra ID.

- **Risk detections** - Contains information about other risks triggered when a risk is detected and other pertinent information such as sign-in location and any details from Microsoft Defender for Cloud Apps.

Next steps

See these security operations guide articles:

Security operations for user accounts

Security operations for consumer accounts

Security operations for privileged accounts

Security operations for Privileged Identity Management

Security operations for applications

Security operations for devices

Security operations for infrastructure

Last updated on 03/27/2026